

PSB CYBERSECURITY, FRAUD AND AI HACKATHON 2026

GAGMA

Graph-Augmented GenAI Malware Analyst

An enterprise-grade, Generative AI-powered Android APK malware reverse engineering, call-graph database modeler, and incident response orchestration gateway. Specifically engineered for the Indian digital banking and financial payments ecosystem.

PROJECT METADATA

Problem Statement: PS1 - Generative AI-Based Automated Analysis of Fraudulent APKs

Target Frameworks: RBI IT & Cybersecurity Framework | CERT-In Compliance SLA

Source Repository: <https://github.com/shree-arun/gagma.git>

Live Demo Server: <http://3.229.117.157>

1. Executive Summary & Core Challenge

Modern digital banking platforms face a highly aggressive wave of mobile malware attacks. Fraudulent Android applications (APKs) targeting digital payment platforms like UPI, net banking, and credentials are systematically distributed via messaging networks, SMS phishing, and fake landing pages. These apps exfiltrate SMS OTP codes, display spoofed login screens, and hijack customer accounts.

Traditional static analysis is too slow and depends heavily on skilled cyber professionals. GAGMA solves this resource gap by combining advanced reverse engineering, dynamic graph-database modeling (Neo4j Call-Graphs), and specialized multi-agent Generative AI. This automated pipeline recovers method calling sequences, queries call-graphs, flags banking risk indicators, and dispatches instant incident response notifications across enterprise networks in under 60 seconds.

2. System Pipeline & Technical Workflow

Step 1: Automated Decompileation

The frontend FastAPI receives the raw APK file. In the backend, a headless decompiler using 'jadx' disassembles compiled dex files, extracting manifest permissions, resource paths, and recovering readable Java classes.

Step 2: Neo4j Call-Graph Ingestion

Extracted static components (method variables, calls, URLs, and hardcoded C2 server IPs) are loaded into a Neo4j Malware Knowledge Graph (MKG). Method nodes map call sequences, and relationships deconstruct permission request loops.

Step 3: Multi-Agent GenAI Analysis

Collaborative AI agents consult the Neo4j graph database to evaluate call-graphs, perform explainable code audits on suspicious blocks, fetch real-time threat intelligence (VirusTotal), and write natural language risk summaries.

3. Key Innovations & Multi-Channel Alerting

During live high-severity threats, delay is the enemy of containment. GAGMA implements multiple layers of notification and demo capabilities for immediate security response:

- **Collapsible CSO Smartphone Mockup**

Displays a floating, glassmorphic phone widget on the dashboard. Upon threat identification, the phone automatically wakes up, glows green, plays a chime, and triggers an interactive simulated WhatsApp quarantine chat drawer.

- **Enterprise SIEM Webhooks**

Dispatches formatted JSON payloads containing full MITRE ATT&CK maps, risk scores, and decompile data straight to corporate Security Operations Centers.

- **Primary Alerts (WhatsApp)**

Wired via a CallMeBot API script, GAGMA streams detailed alert cards directly to security administrators' personal phones.

- **Backup Alerts (Telegram Bot)**

Integrates high-reliability fallback alerts via the official '@GagmaAlertsBot' to bypass WhatsApp rate-limiting or network blockades instantly.

4. Regulatory Compliance & Banking Standards

- **RBI IT Master Direction (2023)**

Automates continuous static/dynamic risk scoring and isolates sensitive API credentials.

- **CERT-In SLA Guidelines**

Reduces threat disclosure time to under 60 seconds with instant multi-channel push warnings.

- **MITRE ATT&CK Framework**

Automatically maps method call patterns to official Mobile Threat Attack matrices.

- **NPCI Digital Payment Protection**

Deploys targeted heuristics to identify overlay layers aimed at UPI, GPay, and major banks.